

ARKE — Pente fino de prontidão

Varredura de 21 de setembro de 2026 · branch `claude/arke-multitenant-reset-8c8xw3`

Escopo desta varredura. Asaas/fintech tratado como evolução futura, catraca como dependente de bancada, e os cinco pontos do Método ARKE como regra comercial — conforme definido. O que sobra aqui é prontidão de *código*.

1. O que está íntegro

Verificado na varredura, não de memória.

Checagem	Resultado
Tabelas sem RLS	zero — a regra 1 do projeto está íntegra
Edge functions: repositório ↔ publicadas	26 = 26 , paridade mantida
Migrations no repositório	114
Cron jobs ativos	8 (ativação, barreira de rotina, SLA, engajamento, acolhimento, financeiro, MRR)
Testes automatizados	152 — 116 no app, 36 no gateway
Funções <code>get_superuser_*</code>	13 de 13 checam o papel por dentro — sem escalada de privilégio
Dados de homologação	1 organização, 10 alunos ativos, 0 CPFs sujos

2. Pontas soltas

2.1 O `.maybeSingle()` voltou — cinco vezes

Eu havia dito que esse padrão merecia uma varredura dedicada e não a tinha feito. Fiz agora. O defeito é sempre o mesmo: consultar `organization_members` por `user_id` sem fixar a organização. Quem tem vínculo ativo em duas academias faz a consulta falhar e leva 403.

Função	Quebra quando	Gravidade
<code>anonimizar-aluno</code>	gestor com 2 vínculos — caminho de LGPD	Alta
<code>gerar-link-ativacao</code>	aluno com 2 vínculos não recebe o link de ativação	Alta
<code>cadastrar-membro-equipe</code>	gestor com 2 vínculos não consegue cadastrar equipe	Média
<code>excluir-aluno</code>	gestor com 2 vínculos não consegue excluir	Média
<code>send-chat-push</code>	destinatário com 2 vínculos não recebe push	Média

E uma variante que eu não havia considerado — filtra a organização corretamente, mas assume **um gestor só**:

Função	Quebra quando	Gravidade
<code>asaas-emitir-cobranca-b2b</code>	academia com dois gestores	Alta
<code>superadmin-suporte-tenant</code>	idem	Média

Dois gestores numa academia é o normal, não a exceção. O pior da lista é o `anonimizar-aluno`: o defeito atinge justamente o caminho de conformidade.

2.2 O gêmeo morto do parser continua vivo

`parsear-dieta-pdf` está **publicado e no repositório**, e **nenhuma tela o chama** — só `parse-dieta-pdf` é usado (`AdminDietas.tsx:363`). É exatamente o tipo de duplicata que atrasou o diagnóstico quando o parser quebrou em produção.

2.3 Higiene de segurança (Supabase advisors)

Achado	Natureza
14 funções de trigger expostas como RPC para <code>anon</code> e <code>authenticated</code>	Não é buraco — chamar fora do contexto de trigger dá erro — mas é superfície desnecessária. Uma delas (<code>exigir_limite_alunos</code>) foi introduzida agora.
9 de 13 <code>get_superadmin_*</code> chamáveis por <code>anon</code>	As outras 4 têm revoke. Todas se protegem por dentro, então não há vazamento — mas a defesa em profundidade está desigual.
<code>limite_padrao_plano</code> com <code>search_path</code> mutável	WARN do advisor. Função introduzida agora.
Proteção contra senha vazada desabilitada	Configuração do Auth. Um toggle no painel do Supabase — ação sua , não de código.

2.4 Pendência antiga, ainda aberta

A causa da orfandade nunca foi explicada. As chaves estrangeiras são `ON DELETE CASCADE` e estão validadas, e ainda assim 18 linhas sobreviveram à exclusão dos pais em setembro. A hipótese — limpeza rodada com `session_replication_role = 'replica'`, que desliga os triggers de FK — nunca foi confirmada. Tratamos o sintoma, não a causa: apagar tenant por fora do produto pode repetir o rastro.

3. Placar

Módulo	Nota	O que segura
Núcleo — auth, RLS, multitenancy	95%	causa da orfandade não explicada
App do aluno	92%	—
Metodologia — prescrição, fases, check-in	90%	os cinco pontos em decisão comercial
Nutrição / parser de PDF	90%	gêmeo morto publicado
Onboarding & importação	88%	dois dos defeitos de vínculo duplo
LGPD	85%	anonimizar-aluno quebrado no vínculo duplo
Higiene de segurança	80%	triggers expostas, RPCs abertas, senha vazada
Catraca	75%	bancada (Control iD) · ponte .NET (Topdata)
Fintech	—	fora de escopo por decisão

~85%

Prontidão geral de código · era 58% (com catraca) / 72% (sem) na primeira auditoria
Julgamento ponderado, não medição — o que é medido são os números da seção 1.

4. Plano de ação

1. **Varredura do `.maybeSingle()`** — 7 funções, correção mecânica com a regra de desempate já estabelecida em `escolherVinculo()` (gestor → professor → nutricionista → aluno, vínculo mais antigo). É **P0** porque uma delas é LGPD e outra é cobrança B2B.
2. **Encerrar o `parsear-dieta-pdf`** — remover do repositório e do ambiente, pelo mesmo critério aplicado às três funções mortas de setembro. O histórico do git preserva o código.
3. **Fechar os advisors** — `revoke execute` nas 14 triggers e nas 9 RPCs de superadmin, `search_path` fixo em `limite_padrao_plano`. O toggle de senha vazada é ação sua no painel.
4. **Testes de borda do receptor Control iD** — payload malformatado, `user_id` não numérico, duas catracas simultâneas da mesma academia, nuvem estourando o timeout no meio de um giro. Verificável sem hardware.
5. **Investigar a orfandade** — a única forma honesta é reproduzir num branch do Supabase.

Os itens **1 a 3** são de baixo risco e alto retorno: levam o placar para perto de **90%** sem depender de hardware, do Asaas nem de decisão comercial.

5. Fora do escopo desta varredura

Frente	Situação
Fintech / Asaas	Tratada como evolução futura. A integração está configurada e funcionando; o que ficou para depois é a rede de segurança de inadimplência B2C e a reconciliação automática gateway ↔ banco.
Catraca Control iD	Implementada e testada com os payloads literais da documentação do fabricante. Falta bancada: timing do giro, sentido de liberação, ergonomia do cadastro de digital e leitura em dedo de academia.
Catraca Topdata	Arquitetura fechada e lado do ARKE pronto. Falta a ponte <code>ArkeInnerBridge</code> em .NET — especificação em <code>docs/PONTE_TOPDATA.md</code> . Destrava com SDK + Kit Integrador, sem precisar de academia.
Henry / Dimep	Sem documentação de integração pública. Conexão vira parte do processo comercial na implantação.
Cinco pontos do Método ARKE	Check-in "com dificuldade" sem dor que não avisa ninguém · barreira de rotina que não filtra por adesão · teto de 80 pontos do Essencial · fase que trava em B.A.S.E.® sem lembrete · UTC das rotinas. São decisões de regra interna, não defeitos.

Gerado em 21/09/2026 a partir de varredura ao vivo do repositório e do projeto Supabase `jbkxrxfdrmrkyldrrdpq`. Os números da seção 1 são medidos; as notas da seção 3 são julgamento ponderado e devem ser lidas como tal.